



Web Application Security

Part 9

Updated Aug 31, 2026

Presented at SNU Chennai

Sivasubramanian Natarajan

Recommended Text books

- Web Application Security, Andrew Hoffman (O'Reilly)
- Grokking Web application security, Malcom Macdonald (Manning Books)

Recap

Previous class Summary

Approach to Web application Security - User Login

- Setup to be implemented for a user login to be orchestrated
- User Registration flow
- User Login Flow
- Session

Definitions

User Registration in an enterprise

A User Registration workflow, before user could access enterprise applications is a critical first step.

- User is provided with a digital identity as part of user joining the enterprise.
- The golden source for digital identity is the Enterprise HRMS system.
- Enterprise applications do not directly connect with Enterprise HRMS for user identity lookup. Instead the User identity from HRMS is sync'ed to a directory service such as LDAP and Active directory and integrated with all internal applications.
- For Critical applications, a system administrator is assigned to register a user with access privilege to the application. Please note that the user already exists in the organization, therefore the administrator is not required to create the user.
- For less critical services user is provided with a self-service registration process.

User Registration in customer facing applications

- Most social media applications facilitate user self-registration.
- For customer facing applications in financial services the user is created with a strong digital identity with additional checks, by the customer officer, such as mobile number verification etc., This is the equivalent of directory services hosted for internal applications.
- Other industries have systems and controls in place to maintain strong digital identity for customer, such as Subscriber ID or Relationship number etc.,

The important question to ask is for understanding what is that golden source of directory in which these customer information is stored. As you can see it varies across industries.

Operationalizing Definitions

Digital Identity

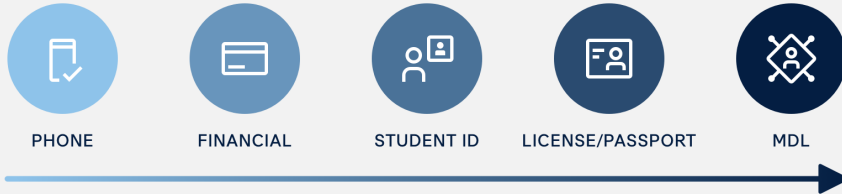
A digital identity is a digital representation of an individual (or entity) in a digital transaction.



SOURCE: BEECK CENTER FOR SOCIAL IMPACT + INNOVATION AT
GEORGETOWN UNIVERSITY, CENTER FOR DEMOCRACY & TECHNOLOGY,
AND THE NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY.

VERSION 1

Types of Evidence for Verification



Some types of identity evidence are stronger than others, depending on how they are created.

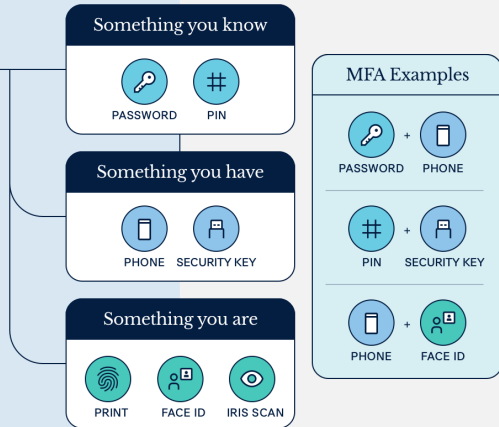
SOURCE: BEECK CENTER FOR SOCIAL IMPACT + INNOVATION AT
GEORGETOWN UNIVERSITY, CENTER FOR DEMOCRACY & TECHNOLOGY,
AND THE NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY.

VERSION 1

Identity providers

- In an enterprise a centralized database such as Active Directory acts as an identity provider, syncing with the master golden source such as HRMS.
- In a customer centric organization the CRM (Customer relationship management) serves as a golden source. Syncing from it the application sets up its authentication database using ORACLE or any such RDBMS
- Federated identity, Suppose the organization do not want its own identity provider they could integration with a third party provider such as Google or Microsoft. This arrangement is called as Federated identity.

Authenticator Examples



SOURCE: BEECK CENTER FOR SOCIAL IMPACT + INNOVATION AT
GEORGETOWN UNIVERSITY, CENTER FOR DEMOCRACY & TECHNOLOGY,
AND THE NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY.

VERSION 1

Identity and access management

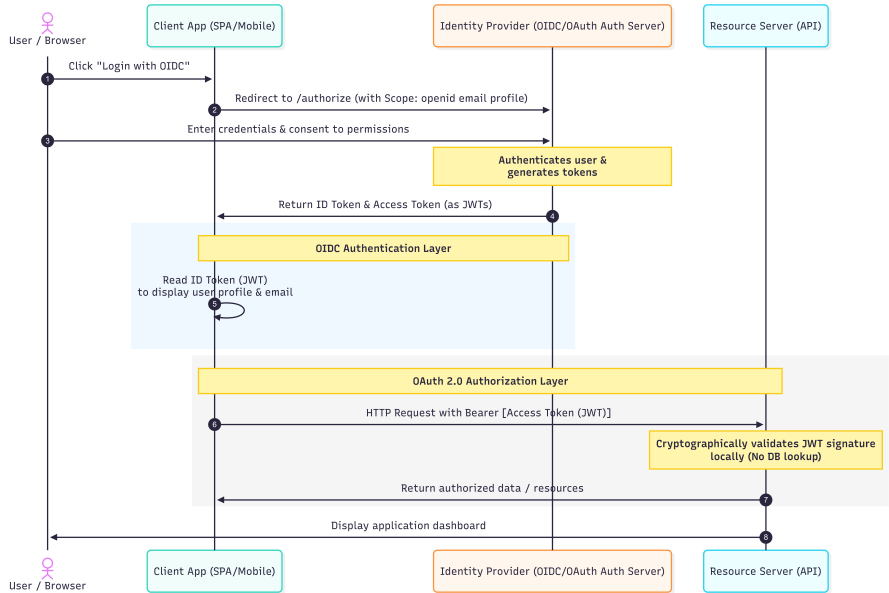
Identity and Access management (IAM) integrates all the definitions into one single workflow

- Authentication is a building block to the larger concept Identity and Access management.
- The authentication workflow for every user involved validating the user identity and then determine within the application what functions / resources user can access.
- Additionally, IAM automates onboarding and offboarding of users, and also monitors their behavior inside your environment to spot any suspicious activity.

NOTE: User provisioning, onboarding or de-provisioning and offboarding are terminologies used interchangeably.

Implementating the envisaged operations in IAM

OIDC, OAUTH2.0 and JWT tokens



Literature

Notes

- <https://heimdalsecurity.com/blog/what-is-user-provisioning/>
- <https://heimdalsecurity.com/blog/identity-and-access-management/>
- <https://digitalgovernmenthub.org/publications/digital-identity-101-an-introduction-to-digital-identity-in-public-benefits-programs/>
- <https://identitymanagementinstitute.org/identity-security-posture-management/>
- <https://www.codemag.com/Article/2312021/Web-Application-Authentication>
- <https://www.microsoft.com/en-in/security/business/security-101/what-is-openid-connect-oidc>
- <https://medium.com/@shubhamatucsd/the-complete-guide-to-oauth-2-0-openid-connect-and-jwt-token-verification-f2516c196f3b>
- <https://www.jwt.io/>

Content references

Common Golden Sources of Identity Organizations generally rely on one of three systems to serve as their primary source of truth:

- **HR Management Systems (HRMS):** This is the most common golden source for internal employees. Examples include Workday, SAP SuccessFactors, or BambooHR. When HR hires an employee, the identity lifecycle automatically begins.
- **Customer Relationship Management (CRM):** This serves as the golden source for external identities, such as clients or citizens. Examples include Salesforce or HubSpot.
- **Supplier/Vendor Portals:** Used for third-party contractors and partners, ensuring their access is strictly tied to active procurement contracts.

Architectural checklists

- What specific system (e.g., Workday, Active Directory, a custom SQL database) are you currently considering as your primary source?
- Are you managing internal employees, third-party contractors, or external customers?
- What Identity and Access Management (IAM) platform (e.g., Okta, Microsoft Entra ID, Ping Identity) are you planning to connect to this source?